

Semana 5

Falsos positivos monitoreo SOC

Divier Jácamo Álvarez

Cetav

Rol: Analista SOC L1

Fecha 12/02/26

Introducción

El monitoreo continuo de SOC se basa en herramientas como SIEM, IDS/IPS y EDR para identificar actividades sospechosas sin embargo, estas tecnologías pueden generar falsos positivos, definidos como alertas que clasifican erróneamente actividades legítimas como maliciosas Este fenómeno es un desafío crítico para la eficacia operativa del equipo de seguridad.

1. Configuración de reglas incorrecta

Las reglas genéricas o mal adaptadas en herramientas como SIEM a menudo generan alertas innecesarias sin adaptarse al contexto organizacional específico la falta de procesos continuos de adaptación aumenta este problema.

2. Falta de contextualización

La falta de información contextual, como perfiles de activos legítimas se interpretan como inusuales

3. Cambios en el entorno tecnológico

La migración a la nube, nuevas aplicaciones o cambios en la infraestructura cambian los patrones de comportamiento normales. Si las herramientas no se actualizan con estos cambios, se muestran advertencias inapropiadas.

4. Limitaciones tecnológicas

Los sistemas basados en firmas pueden generar coincidencias parciales con acciones legítimas, mientras que los modelos de aprendizaje automático pueden producir errores si no tienen suficientes datos de entrenamiento

5. Factores organizacionales

la mala formación y la falta de métricas claras contribuyen a una gestión de alertas ineficaz y a una mayor percepción de falsos positivos.

Ejemplos de falsos positivos

1. Múltiples intentos fallidos de autenticación debido a que se olvidó la contraseña

Escenario: Un usuario intenta repetidamente acceder a un sistema crítico de la empresa y falla cinco veces seguidas.

Alarma generada: Es posible un ataque de fuerza bruta.

Análisis real: Después del cambio de credencial obligatorio, el usuario ha olvidado su contraseña.

Motivo del resultado falso positivo: La regla se configura sin tener en cuenta el contexto

2. Escaneo interno autorizado

Escenario: El equipo de infraestructura realiza pruebas de vulnerabilidad programadas utilizando herramientas como Nessus u Open VAS.

Alarma generada: Actividad sospechosa de escaneo o reconocimiento de puertos.

Análisis real: Actividad legítima confirmada como parte del plan de vulnerabilidad.

Motivo del resultado falso positivo: Falta de comunicación entre equipos y falta de exclusión en SIEM.

3. Transferencia masiva de datos con copia de seguridad programada

Escenario: Se ejecuta una copia de seguridad nocturna, que transfiere una gran cantidad de información al servidor de copia de seguridad.

Alarma generada: Posible filtración de datos.

Análisis real: Proceso de copia de seguridad autorizado automatizado.

Motivo del resultado falso positivo: La regla se basa únicamente en la cantidad de datos transferidos sin un análisis de objetivos fiable.

4. Acceso remoto legal desde una nueva ubicación

Escenario: Un empleado accede al sistema de la empresa desde otra ciudad debido a un viaje de negocios.

Alarma generada: Acceso sospechoso desde una ubicación inusual.

Análisis real: Actividad laboral jurídica.

Motivo del resultado falso positivo: Modelo de detección de anomalías sin actualización dinámica del perfil de usuario.

5. Instalación legal de software administrativo

Escenario: El departamento de TI instala una herramienta de administración remota en varios ordenadores.

Alarma generada: Potencialmente explotando una herramienta de acceso remoto

Análisis real: La implementación está confirmada por la política de la empresa.

Motivo del resultado falso positivo: Firmas coincidentes asociadas con herramientas que también pueden ser utilizadas por atacantes.

6. Automatización DevOps en el entorno de la nube

Escenario: Una canalización automatizada crea y elimina varias instancias de la nube en cuestión de minutos.

Alarma generada: Comportamiento anormal o posible actividad de ataque automatizado.

Análisis real: Proceso normal de implementación continua

Motivo del resultado falso positivo: Las herramientas de monitoreo no están adaptadas a la naturaleza dinámica del entorno de la nube.

7. Envío masivo de correos electrónicos internos

Escenario: El área de personal envía un aviso institucional a todos los empleados.

Alarma generada: Posible campaña de phishing interno.

Análisis real: Comunicación oficial jurídica. Motivo del resultado falso positivo:

Reglas basadas en volumen de envío sin validación de dominio o cuenta comercial autorizada.

Procedimiento para descartar falsos positivos

Introducción

El descarte adecuado de falsos positivos es esencial para mantener la eficiencia operativa de un SOC y reducir la fatiga de alertas. Para ello, es necesario aplicar criterios técnicos, contextuales y procedimentales que permitan clasificar correctamente las alertas sin comprometer la seguridad.

1. Criterios Contextuales

Comportamiento histórico del usuario: Verificar si la actividad coincide con patrones habituales (horarios, ubicación, dispositivos).

Rol y privilegios: Confirmar que la acción corresponde a funciones autorizadas del usuario.

Se descarta si la actividad es coherente con el perfil y no existen indicadores adicionales de compromiso.

2. Criterios Técnicos

Validación de infraestructura confiable: Confirmar que IP, dominio o servidor pertenezcan a activos autorizados.

Correlación de eventos: Determinar si existen otros eventos relacionados que respalden la sospecha.

Se descarta si el evento es aislado y no muestra evidencia técnica adicional.

3. Criterios Operativos

Cambios autorizados: Verificar si la actividad corresponde a mantenimientos, respaldos o escaneos programados.

Confirmación con áreas técnicas: Validar con el equipo responsable si la actividad fue legítima.

Se descarta cuando existe documentación o confirmación formal.

4. Criterio de Evaluación de Riesgo

Antes de cerrar la alerta, el analista debe evaluar:

¿Existe evidencia concreta de compromiso?

¿El activo es crítico?

¿Hay múltiples indicadores de ataque?

Si el riesgo es bajo y existe justificación documentada, la alerta puede clasificarse como falso positivo.

Documentación del proceso de validación de las alertas

Proceso de reconocimiento de alertas en el SOC

1. Establecer objetivos

Establecer un procedimiento estandarizado para validar, clasificar y cerrar las alertas generadas por las herramientas de monitoreo de SOC, garantizando consistencia, trazabilidad y reduciendo falsos positivos sin comprometer la detección de eventos reales.

2. Ámbito de actividad

Este proceso se aplica a todas las alertas generadas por plataformas de monitoreo como SIEM, EDR, IDS/IPS, herramientas de seguridad en la nube y sistemas de correlación de eventos.

3. Funciones y responsabilidades

Analista Nivel 1: Ingesta, análisis inicial y clasificación inicial. Analista Nivel 2: Análisis profundo y correlación avanzada.

SOC Manager / Incident Handler: Aprobación final en casos críticos y escalamiento.

4. Flujo del proceso de validación

Registro automático en la plataforma de gestión de incidencias. Priorización según la gravedad que determine la herramienta.

Resultado esperado: Alarma formalmente documentada y asignada.

Para el analista:

Revise el tipo de alerta y la regla que la generó.

Identifique el usuario, el recurso, la IP de origen/destino y la marca de tiempo. Evaluar la criticidad del bien afectado.

Decisión provisional:

Posible evento. Leve sospecha.

Posiblemente un falso positivo.

Consulte registros adicionales

Analizar eventos relacionados en una ventana de tiempo cerrada. Consultar indicadores de reputación

Objetivo: Determinar si existen múltiples indicadores que coincidan con el ataque.

Revisar el historial de usuarios o activos.

Verificar cambios autorizados Confirmar en las áreas técnicas que la operación es legal.

Clasificación de alarmas

La advertencia debe clasificarse como:

Evento aprobado

Falso positivo confirmado

Actividad legal documentada

Alerta de información

Cada clasificación debe tener una justificación técnica documentada.

Aumenta a un nivel superior si:

El activo es crítico.

Hay evidencia de una compensación. La acción continúa o se intensifica.

Llenado y documentación

Para cerrar la alerta:

Se ha realizado un análisis del expediente. Agregue evidencia técnica.

Indique la causa raíz. Recomendar corrección de reglas, si corresponde.

5. Criterios de calidad del proceso

El proceso debe asegurar:

Trazabilidad total.

Tiempo de respuesta según SLA. Reducción progresiva de falsos positivos.

Mejora continua mediante adaptación de reglas

6. Indicadores de desempeño

Un falso positivo. Tiempo medio de análisis

Tiempo medio de respuesta porcentaje de alertas clasificadas correctamente.

Conclusión

La validación de las alertas en el SOC debe realizarse mediante un procedimiento estructurado que combine análisis técnico, contextual y organizativo. La estandarización del proceso permite reducir la incertidumbre en la toma de decisiones, optimizar recursos y fortalecer la capacidad real de detección frente a amenazas.

Referencias

Ahmad, A., Hadgkiss, J., & Ruighaver, A. B. (2012). Incident response teams—Challenges in supporting the organisational security function. *Computers & Security*, 31(5), 643–652. <https://doi.org/10.1016/j.cose.2012.04.001>

Axelsson, S. (2000). The base-rate fallacy and its implications for the difficulty of intrusion detection. *Proceedings of the 6th ACM Conference on Computer and Communications Security*, 1–7. <https://doi.org/10.1145/352600.352606>

Cichonski, P., Millar, T., Grance, T., & Scarfone, K. (2012). *Computer security incident handling guide (NIST Special Publication 800-61 Rev. 2)*. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-61r2>

Shackleford, D. (2015). *Who's watching the watchers? Improving security operations center practices*. SANS Institute.

Brown, S., & Gommers, J. (2019). SOC automation and orchestration: Reducing alert fatigue. *SANS Reading Room*.